

NETWORKWALKS CYBERSECURITY INTERNSHIP

Penetration Testing Report

Mediroza General Hospital — Black-Box Web Application Pentest

Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Black-box Penetration Test
Batch / Week	NetworkWalks Batch B083 — Week 4
Duration	5 Days
Authorization	Written permission granted by client (per engagement brief)
Classification	CONFIDENTIAL — Authorised Personnel Only

This engagement was conducted in a controlled training environment for educational purposes, with written authorization from the client, as part of the NetworkWalks Cybersecurity Internship. These techniques must never be applied to any system without explicit written permission from the owner.

1. Executive Summary

NetworkWalks conducted a black-box penetration test against Mediroza General Hospital's patient portal (medirozahospital.com) over a 5-day window. The objective was to assess the security of the public-facing web application and identify any weaknesses that could expose confidential patient or business data.

The assessment identified a **critical chain of vulnerabilities** that, together, allowed an unauthenticated attacker to fully compromise patient confidentiality and expose sensitive internal business data. Starting from passive reconnaissance, the tester discovered an exposed legacy directory containing a full database backup, bypassed the patient portal's authentication using SQL injection, and used an insecure direct object reference (IDOR) to download confidential pathology reports for three patients. The recovered PDF reports were protected with weak, dictionary-crackable passwords. Separately, the exposed database backup directly disclosed the salaries and national ID numbers of 30 staff members and the full shareholder register of the hospital.

Overall risk to the client is rated **Critical**. The combination of an exposed backup directory, a SQL-injectable login form, and an IDOR on the document download endpoint represents a severe breach risk for a healthcare provider, with direct exposure of PHI-equivalent data, staff PII, and financial/ownership records.

Finding	Category	Risk
F1 — Information disclosure via robots.txt	Reconnaissance	Informational
F2 — Exposed legacy directory with DB backup	Broken Access Control	Critical
F3 — SQL injection / authentication bypass (login)	Injection	Critical
F4 — IDOR on patient document download endpoint	Broken Access Control	High
F5 — Weak encryption passwords on confidential PDFs	Cryptographic Failure	Medium
F6 — Sensitive staff & shareholder data exposure	Data Exposure	Critical

2. Scope and Methodology

Target: <https://medirozahospital.com>

Scope: Full black-box penetration test limited to the target domain. Identify vulnerabilities, exploit them to demonstrate real-world impact, and document all findings in a professional report.

Rules of engagement: Testing limited to the target domain only. No social engineering. No denial-of-service testing. No testing outside the agreed scope.

Methodology: Testing followed a standard black-box web application methodology:

- Passive & light-active reconnaissance (whois, whatweb, nslookup, dnsrecon, robots.txt / sitemap review)
- Attack surface mapping (directory discovery, endpoint enumeration)
- Authentication testing (error-based behaviour, SQL injection)
- Authorization testing (IDOR / object reference enumeration)
- Post-exploitation data analysis (file property / metadata review, credential recovery)

Tools used: curl, nslookup, whatweb, whois, dnsrecon, wafw00f, pdfcrack, John the Ripper (password.lst wordlist), pdf2john, and NetworkWalks' online Hash Calculator / Password Cracker utilities.

3. Findings and Proof of Exploitation

F1 — Information Disclosure via robots.txt

Risk Rating: Informational

A request to `/robots.txt` revealed Disallow entries for `/patient/`, `/staff/` and `/old/`. While intended to keep these paths out of search engine indexes, `robots.txt` is publicly readable and effectively mapped out sensitive directories for the tester, directly seeding the next finding.

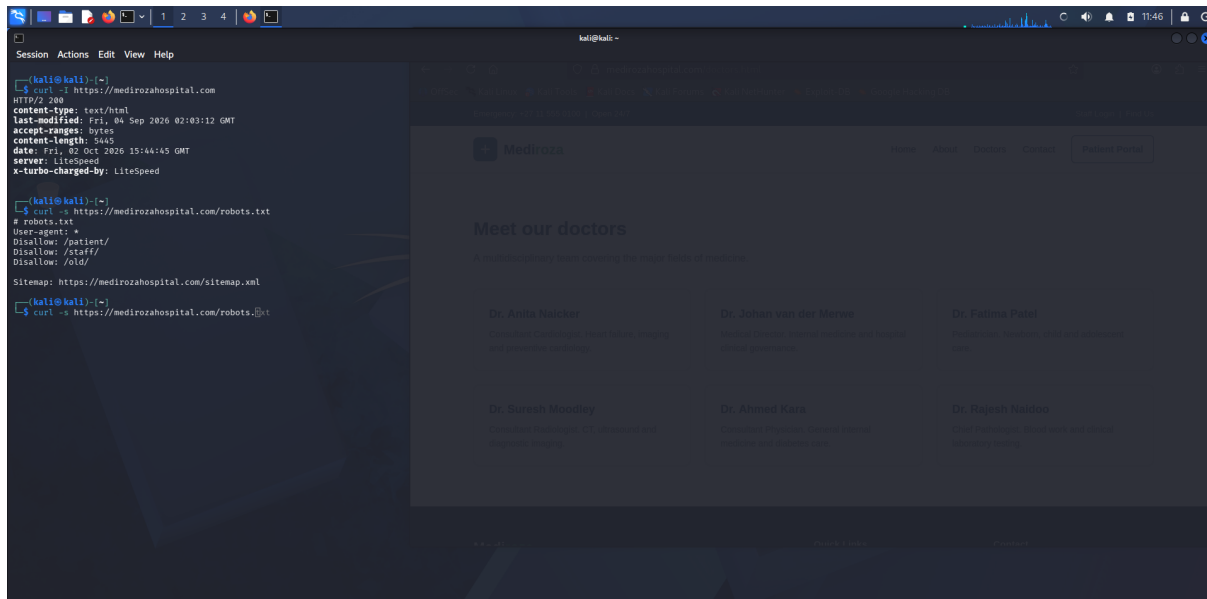


Figure 1 — `robots.txt` disclosing `/patient/`, `/staff/` and `/old/` as disallowed (hidden) paths.

F2 — Exposed Legacy Directory with Full Database Backup

Risk Rating: Critical

Browsing to `/old/` (flagged by `robots.txt`) returned a fully browsable directory listing served directly by the web server, with no authentication. The listing exposed `mediroza_db_backup_2019.sql` — a complete database backup — which was downloaded directly over HTTP.

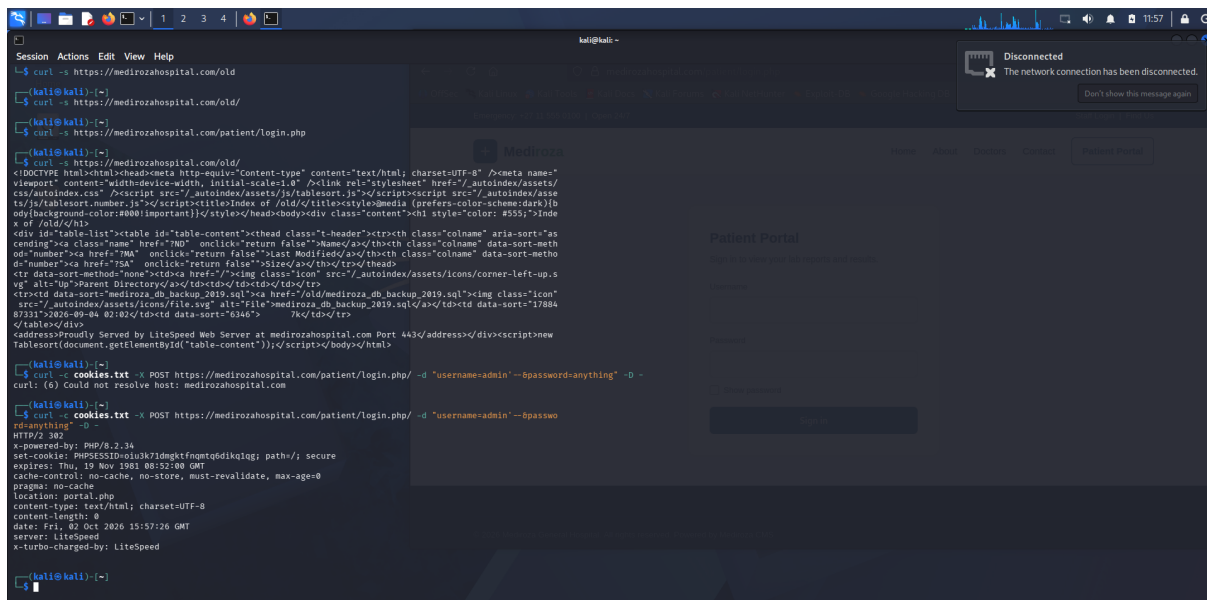


Figure 2 — Directory listing of /old/ exposing mediroza_db_backup_2019.sql, and the subsequent authentication bypass request shown in the same terminal session.

F3 — SQL Injection / Authentication Bypass on Patient Login

Risk Rating: Critical

The patient portal login (/patient/login.php) was tested with a classic SQL injection payload in the username field: `username=admin' - -&password=anything`. The server responded with HTTP/2 302 and a redirect to portal.php, along with a valid session cookie — confirming the login query is not parameterised and authentication can be bypassed without valid credentials.

See Figure 2 above for the full request/response showing the 302 redirect and session cookie issuance.

F4 — IDOR on Patient Document Download Endpoint

Risk Rating: High

Using the session cookie obtained via F3, the document endpoint /patient/download.php?id=N was found to return any patient's PDF report by simply incrementing the id parameter — with no check that the authenticated session owns that document. IDs 1, 2 and 3 were requested sequentially and all three confidential pathology reports were retrieved.

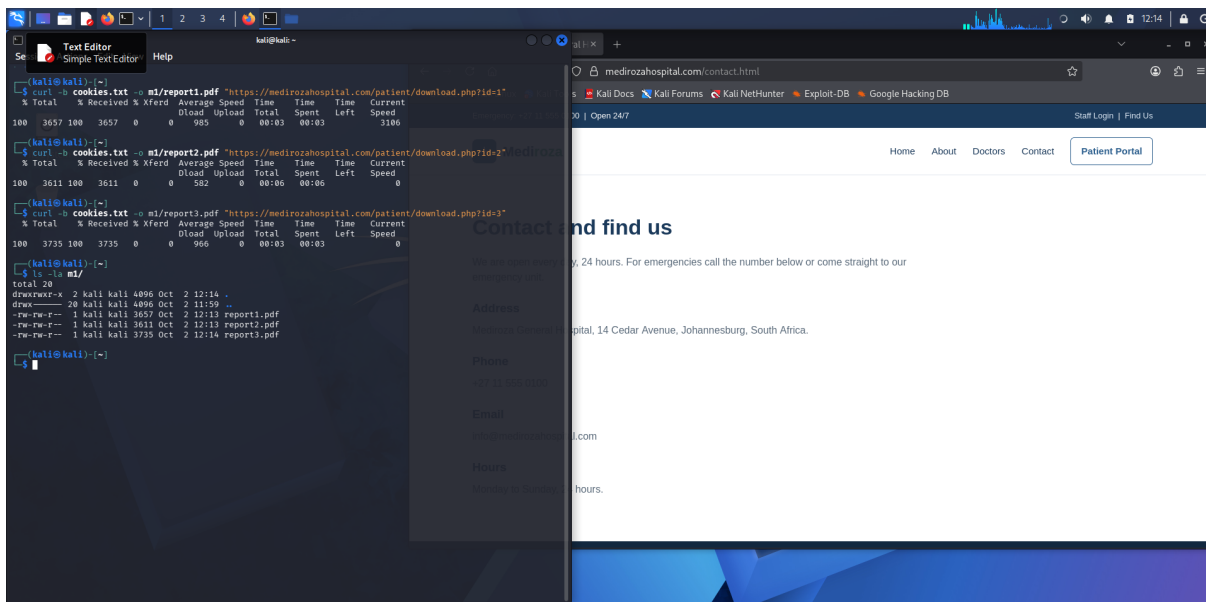


Figure 3 — Sequential download of report1.pdf, report2.pdf and report3.pdf via download.php?id=1/2/3 using the authenticated session cookie.

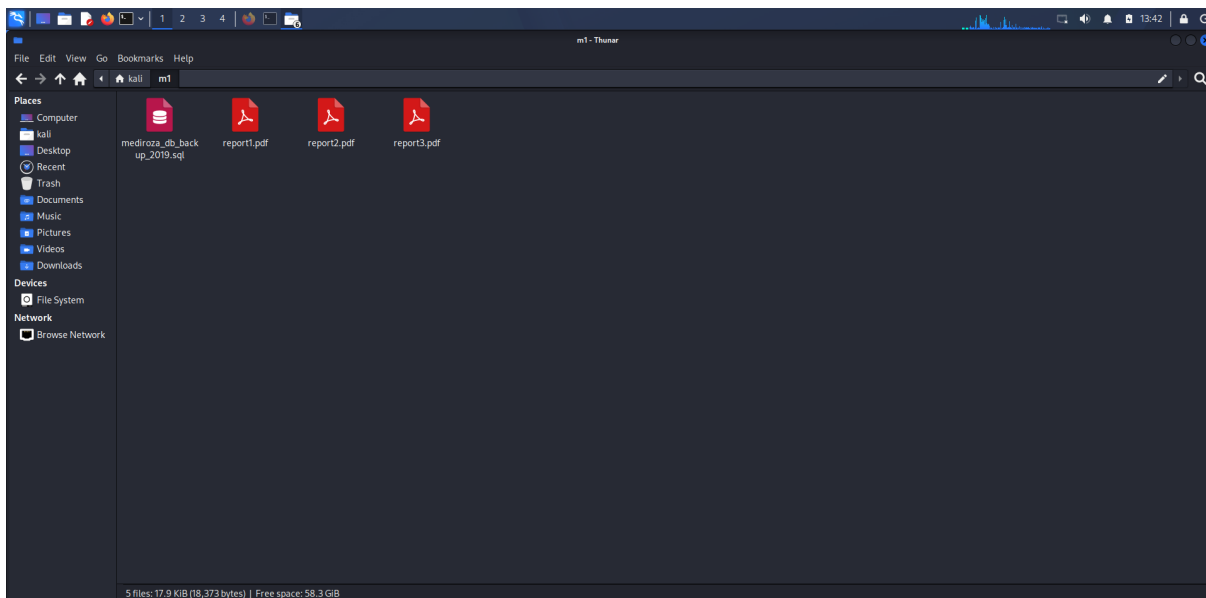


Figure 4 — Final set of retrieved files: the database backup and three confidential patient PDF reports.

F5 — Weak Encryption Passwords on Confidential PDF Reports

Risk Rating: Medium

All three retrieved PDF reports were password-protected (PDF Standard Security Handler, Revision 3, 128-bit). Each file required a different cracking approach, confirming inconsistent and generally weak password hygiene:

- **report1.pdf** (patient: S. Dlamini) — hash extracted and cracked via dictionary attack. Password: **123456**.
- **report2.pdf** (patient: P. Reddy) — hash extracted and cracked via dictionary attack. Password: **password**.
- **report3.pdf** (patient: E. Thompson) — not in the small built-in wordlist; required pdfcrack with John the Ripper's larger password list. Password: **!@#\$%^&**.

All three passwords fall within common/default password lists, meaning the encryption provides little real protection against a motivated attacker.

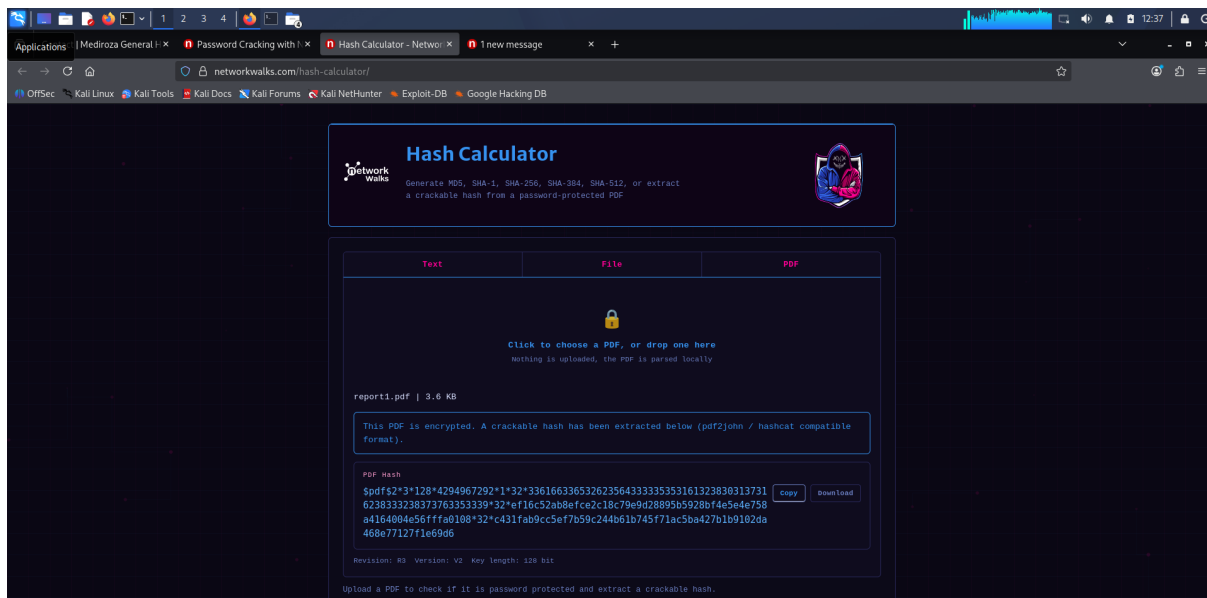


Figure 5 — Hash extracted from report1.pdf (PDF R3 / 128-bit).

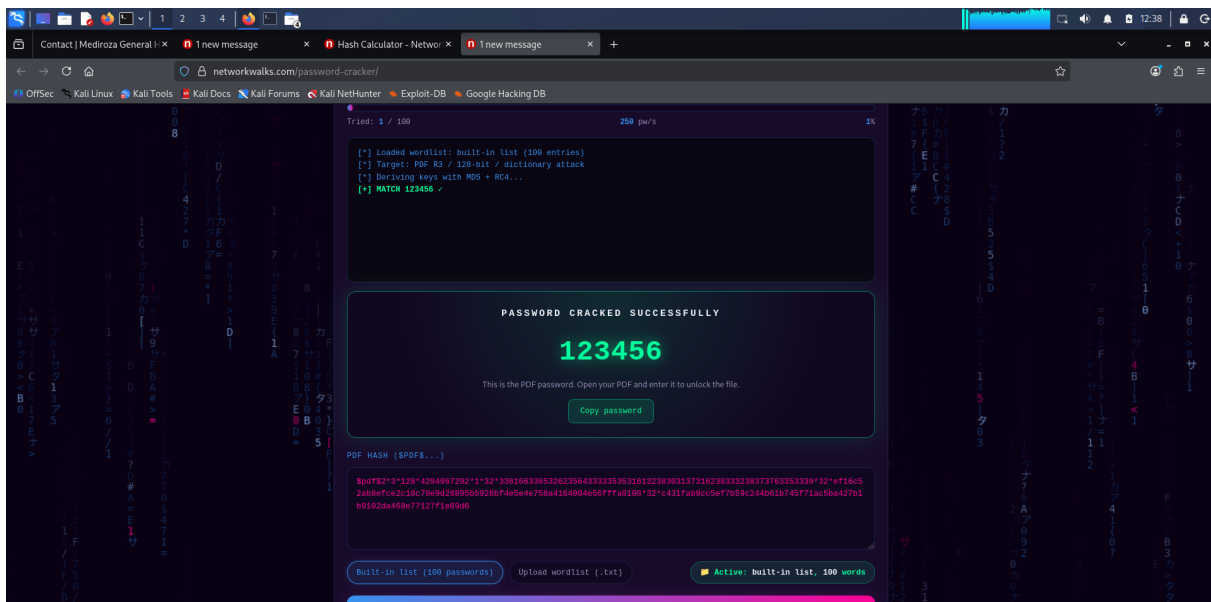


Figure 6 — report1.pdf cracked via dictionary attack — password '123456'.

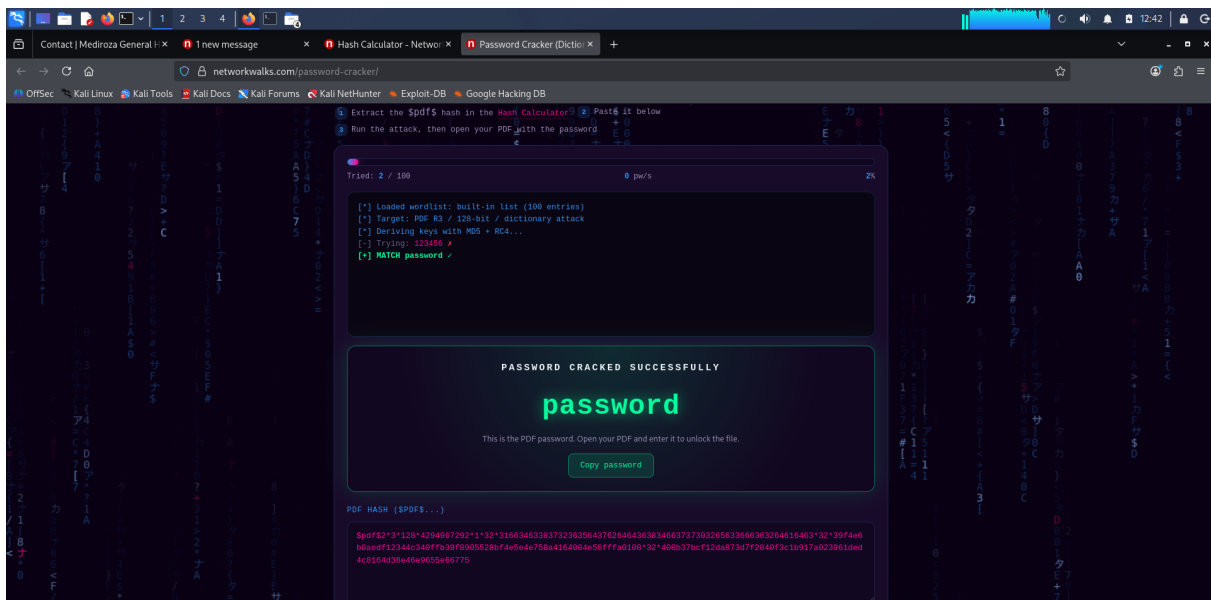


Figure 7 — report2.pdf cracked via dictionary attack — password 'password'.

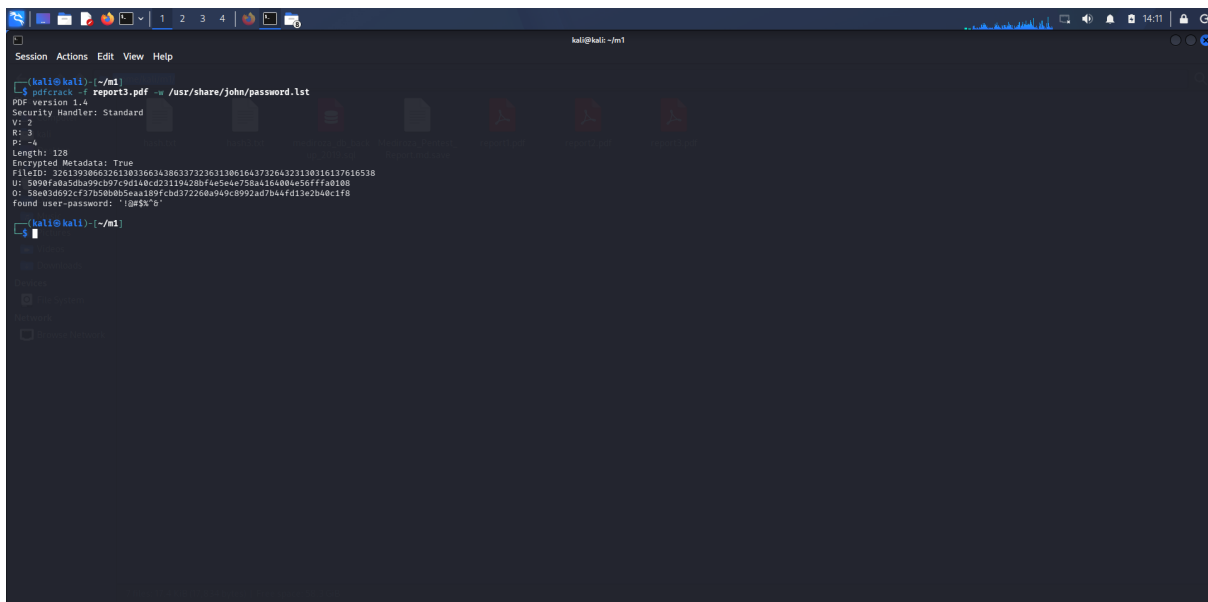


Figure 8 — report3.pdf cracked using pdfcrack with John's password.lst wordlist — password '!@#\$\$%^&'.

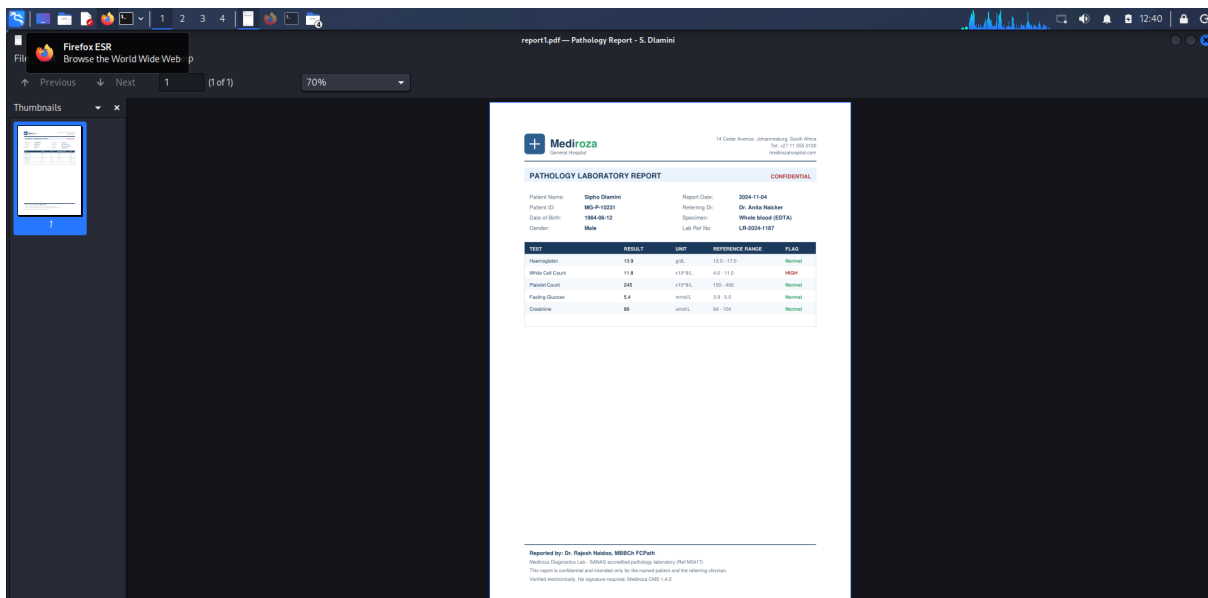


Figure 9 — report1.pdf opened, confirming confidential patient pathology data (Patient: S. Dlamini).

F6 — Sensitive Staff and Shareholder Data Exposure

Risk Rating: Critical

Analysis of the database backup obtained in F2 (mediroza_db_backup_2019.sql) showed it was far more sensitive than its filename suggested. The file's own header comment explicitly warns: *"WARNING: contains confidential staff and shareholder records."* The dump contains two fully populated tables:

- **staff** — 30 records including full name, job title, department, email, phone, national ID number and monthly salary (ZAR) for every employee, from the Medical Director down to ward clerks.
- **shareholders** — full share register including shareholder names, ownership percentage, shares held and share class — effectively exposing the hospital's ownership structure.

This single unauthenticated file download exposed personally identifiable information (PII) for every staff member and confidential corporate ownership data — satisfying both M3 objectives (staff salaries and shareholder details) without requiring any further pivot beyond the F2 directory exposure.

```

1| mediroza_db_backup_2019.sql
2| Mediroza General Hospital - internal database backup
3| Generated by Mediroza CMS 1.4.2 backup module
4| Host: localhost  Database: mediroza_hr
5| WARNING: contains confidential staff and shareholder records
6| Backup date: 2019-08-27 02:14:03
7
8 SET NAMES utf8mb4;
9 SET FOREIGN_KEY_CHECKS = 0;
10
11
12 -- Table structure for table 'staff'
13 --
14 DROP TABLE IF EXISTS `staff`;
15 CREATE TABLE `staff` (
16   `id` int(11) NOT NULL AUTO_INCREMENT,
17   `full_name` varchar(120) NOT NULL,
18   `job_title` varchar(120) NOT NULL,
19   `department` varchar(50) NOT NULL,
20   `email` varchar(120) NOT NULL,
21   `phone` varchar(20) NOT NULL,
22   `national_id` varchar(20) NOT NULL,
23   `monthly_salary_zar` int(11) NOT NULL,
24   `date_joined` date NOT NULL,
25   PRIMARY KEY (`id`)
26 ) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
27
28 --
29 -- Dumping data for table 'staff'
30 --
31 LOCK TABLES `staff` WRITE;
32 INSERT INTO `staff` (`id`, `full_name`, `job_title`, `department`, `email`, `phone`, `national_id`, `monthly_salary_zar`, `date_joined`) VALUES
33 ((, 'Dr. Rajesh Naidoo', 'Chief Pathologist', 'Diagnostics Lab', 'r.naidoo@medirozahospital.com', '+27 82 101 2007', '85021013011081', 138000, '2009-03-16'),
34 ((, 'Sarah Botha', 'Chief Financial Officer', 'Finance', 's.botha@medirozahospital.com', '+27 82 102 2014', '85031023022082', 152000, '2011-07-01'),
35 ((, 'Dr. Johan van der Merwe', 'Medical Director', 'Management', 'j.merwe@medirozahospital.com', '+27 82 103 2021', '85041033033083', 160000, '2007-02-22'),
36 ((, 'Dr. Anita Naicker', 'Consultant Cardiologist', 'Cardiology', 'a.naicker@medirozahospital.com', '+27 82 104 2026', '85051043044084', 132000, '2012-09-10'),
37 ((, 'Dr. Ahmed Kara', 'Consultant Physician', 'Internal Medicine', 'a.kara@medirozahospital.com', '+27 82 105 2035', '85061053055085', 128000, '2013-02-18'),
38 ((, 'Dr. Yusuf Cassim', 'Senior Registrar', 'Emergency & Trauma', 'y.cassim@medirozahospital.com', '+27 82 106 2042', '85071063066086', 74000, '2018-05-04'),
39 ((, 'Michael Roberts', 'HR Director', 'Human Resources', 'm.roberts@medirozahospital.com', '+27 82 107 2049', '85081073077087', 90000, '2010-11-15'),
40 ((, 'Susan Pretorius', 'HR Officer', 'Human Resources', 's.pretorius@medirozahospital.com', '+27 82 108 2056', '85091083088088', 32000, '2016-08-23'),
41 ((, 'Jameel Malik', 'IT Systems Administrator', 'IT', 'j.malik@medirozahospital.com', '+27 82 109 2063', '85101093099089', 58000, '2015-04-12'),
42 ((, 'Rhabo Molefe', 'Network Engineer', 'IT', 'r.molefe@medirozahospital.com', '+27 82 110 2070', '85111103110091', 46000, '2017-10-02'),
43 ((, 'Nomvula Khumalo', 'Registered Nurse', 'Emergency & Trauma', 'n.khumalo@medirozahospital.com', '+27 82 111 2077', '85121113121092', 34000, '2016-01-19'),
44 ((, 'Lerato Mokoena', 'Registered Nurse', 'Pediatrics', 'l.mokoena@medirozahospital.com', '+27 82 112 2084', '8501112312083', 33000, '2017-06-07'),
45 ((, 'Roseann Mlomo', 'Registered Nurse', 'Cardiology', 'r.mlomo@medirozahospital.com', '+27 82 113 2091', '85021133131093', 15000, '2015-12-01');

```

Figure 10 — Database backup header and 'staff' table schema/data: names, national IDs, and monthly salaries.

Figure 11 — 'shareholders' table: names, ownership percentage and shares held.

4. Risk Rating Summary

Ratings follow a standard Critical / High / Medium / Low / Informational scale, based on the sensitivity of data exposed, ease of exploitation, and impact to the client.

ID	Finding	Likelihood	Impact	Overall Risk
F1	robots.txt information disclosure	High	Low	Informational
F2	Exposed /old/ directory with DB backup	High	Critical	Critical
F3	SQL injection / auth bypass on login	High	Critical	Critical
F4	IDOR on document download endpoint	High	High	High
F5	Weak PDF passwords	Medium	Medium	Medium
F6	Staff & shareholder data exposure	High	Critical	Critical

5. Recommendations and Remediation

F1 — robots.txt disclosure

Do not rely on robots.txt to hide sensitive paths — it is publicly readable. Remove references to sensitive directories and instead enforce authentication/authorization at the server level.

F2 — Exposed /old/ directory

Remove the /old/ directory (and any other legacy/staging content) from the production web root immediately. Disable directory listing (autoindex) server-wide. Store backups outside the web root, encrypted at rest, with access restricted to authorized administrators only.

F3 — SQL injection / auth bypass

Rewrite all database queries to use parameterised queries / prepared statements — never concatenate user input into SQL. Add server-side input validation and a Web Application Firewall rule set for injection patterns as a defence-in-depth measure. Conduct a full code review of all other forms for the same vulnerability class.

F4 — IDOR on download endpoint

Enforce object-level authorization on every document request: verify the authenticated session's patient ID owns the requested document ID before serving it. Replace sequential integer IDs with non-guessable identifiers (e.g. UUIDs) as a secondary control.

F5 — Weak PDF passwords

Replace PDF password protection with proper access-controlled delivery (e.g. authenticated download only, no standalone encrypted file). Where PDF encryption is still used, enforce a strong, unique, system-generated password per document rather than user-chosen or default passwords.

F6 — Staff & shareholder data exposure

Treat this backup file as a confirmed data breach of staff PII and corporate ownership records: rotate any credentials or identifiers that may have been reused elsewhere, and assess breach notification obligations. Going forward, ensure backups are never stored in a web-accessible location, and classify/encrypt HR and financial data at rest.

Priority: F2, F3 and F6 should be remediated immediately (same day) given the severity and ease of exploitation. F4 should follow within the week. F5 and F1 should be addressed as part of the next scheduled release cycle.

This report was prepared as part of the NetworkWalks Cybersecurity Internship (Batch B083), Week 4 project. Conducted in a controlled environment for educational purposes with written client authorization. These techniques must never be applied to any system without explicit written permission from the owner.